

ScholarBase

Quality Assurance & Security Test Report

Unit • Integration • API E2E • OWASP API Security Top 10 (2023) • UAT

Application	ScholarBase - university question-paper, notes & study-room platform
Stack under test	NestJS 10 + Prisma 5 / PostgreSQL (Neon) / S3-compatible storage / React 18 + Vite
Modules covered	Auth & email verification, paper gating, file storage, study rooms (presence, chat, WebRTC signalling), shared whiteboard, screen-share pointer
Test cases executed	236 (Unit 61, Integration 74, E2E+Security 63, Realtime 21, UAT 17)
Automated result	135/135 Jest specs passed; 21/21 realtime checks passed; 48 passed / 9 failed in the API suite
Defects	19 total - 13 open (1 High, 7 Medium, 5 Low), 6 fixed this cycle
Report date	14 August 2026

All results in this report were produced by executing the test suites against a running instance of the application. No result is estimated or inferred. The suites are committed to the repository and can be re-run to reproduce every number (see Appendix A).

1. Executive summary

ScholarBase's **authentication core remains its strongest area**. Every privilege-escalation and token-forgery attempt failed again this cycle: admin-only routes rejected student tokens, a JWT forged with the real signing secret claiming `role=ADMIN` was still refused because the role is re-read from the database, and mass-assignment of an admin role at signup was blocked by validation whitelisting. Email verification now gates login, and the whole flow - signup issuing no session, a 403 until confirmed, single-use tokens, graceful replay - was verified against real delivery through Brevo.

Two features were added and tested since the last report: a **shared whiteboard** and a **screen-share laser pointer**, both server-relayed so they keep working for students whose peer connection never establishes. All 21 realtime checks pass, including every authorization rule - drawing without a grant is ignored, a non-owner cannot clear the board, and signalling aimed at a non-member socket is refused.

Six defects were fixed this cycle, three of them High. The most serious was QA-17: students reported a call where one person saw everyone, one saw two and one saw only themselves. It was never a network problem - it was offer/answer glare with no arbitration, no error containment and no retry. QA-18 had locked the administrator out of their own site, and QA-20 was blocking every deployment.

The remaining priority is unchanged and now overdue: QA-01, rate limiting. Nothing throttles anywhere. With students actively using the site and email on the signup critical path, an unthrottled resend-verification endpoint can exhaust the 300/day mail quota and lock out real signups, quite apart from making password guessing practical.

1.1 Results by phase

Phase	Cases	Passed	Failed	Focus
Unit	61	61	0	Pure logic: durations, MIME allowlist, header sanitisation, DTO validation rules
Integration	74	74	0	Services against mocked Prisma: credential handling, reset-token lifecycle, upload rules
API E2E	18	15	3	Black-box HTTP: auth lifecycle, catalogue reads, presigned URL issuance
Security (OWASP)	39	27	10	API1-API10 probes against the running server
Realtime	21	21	0	Two live socket clients: presence, chat, whiteboard, pointer, signalling relay
UAT	17	17	0	Browser-driven end-user journeys, responsive and theme checks

The three E2E failures are environmental, not defects: local object storage was offline during the run, so presigned-URL retrieval returned 500. That path was verified working earlier in the same environment and is tracked as an environment note, not a bug.

1.2 Defects by severity

Severity	Count	Meaning
Critical	0	Exploitable now with direct loss of data or full account control
High	4	Directly exploitable by an unauthenticated attacker; fix before public launch
Medium	9	Meaningful weakening of a security or reliability guarantee; fix soon after launch
Low	6	Hardening, defence-in-depth or user-visible polish

1.3 Controls verified as working

These are not assumptions - each was actively attacked or exercised and held.

Control	Evidence	Test IDs
Function-level authorisation	All 7 admin-only routes rejected a student token with 403, and anonymous callers with 401.	SEC-API15-001..007
JWT handling	Malformed, wrong-secret, alg:none and expired tokens were all rejected with 401.	SEC-API12-001..005
Role integrity	A token forged with the real signing secret claiming <code>role=ADMIN</code> was still refused - role is re-read from the database, not trusted from the claim.	SEC-API12-006
Mass assignment	Passing <code>role=admin</code> at signup is rejected outright by ValidationPipe whitelisting.	SEC-API13-001

Control	Evidence	Test IDs
Credential hygiene	No password hash, argon2 material or token hash appears in any API response. Passwords are argon2-hashed; refresh and reset tokens are stored only as HMACs.	SEC-API3-002, IT-AUTH-003/007/013
Token lifecycle	Refresh tokens rotate, replay of a consumed token is rejected, logout revokes, and a password reset revokes every live session atomically.	E2E-009, SEC-API2-007, IT-AUTH-023
Reset-link safety	Reset tokens are single-use, expiry-checked, domain-separated from refresh tokens, and invalidated when a newer link is issued.	IT-AUTH-012/014/020/021
Injection resistance	Prisma parameterises all queries and DTO validation rejects non-UUID input before it reaches the ORM.	SEC-INJ-001, UT-DTO-015
Error hygiene	Malformed requests return generic bodies - no stack traces, file paths or SQL leaked.	SEC-API8-006
Header injection	Quote, backslash and CRLF characters in filenames are neutralised before entering Content-Disposition.	UT-ST0-003/004/005

2. Defect register

Every defect below was reproduced by an executed test. The 'Evidence' line names the test case that demonstrates it, so each can be re-verified after a fix.

QA-01	High	No brute-force protection on authentication	OWASP API4	OPEN
Observed	25 consecutive failed logins were all processed (~3s, zero 429s). No rate limiter is registered, so password guessing is bounded only by network speed. More urgent now that resend-verification and forgot-password can also burn the 300/day Brevo quota.			
Evidence	SEC-API4-001, SEC-API6-001			
Remediation	Add @nestjs/throttler globally, with tighter per-route limits on the auth endpoints.			

QA-02	Medium	Forgot-password timing reveals whether an account exists	OWASP API6	OPEN
Observed	Registered addresses averaged 656ms against 88ms for unregistered (7.45x). The registered branch does two extra DB writes and an awaited outbound mail call; the uniform response body does not hide that.			
Evidence	SEC-API6-002, IT-AUTH-018			
Remediation	Dispatch the mail without awaiting it, or normalise total handler time.			

QA-03	Medium	Database error on forgot-password creates a 500-vs-200 oracle	OWASP API6	OPEN
Observed	The passwordResetToken writes sit outside the try/catch guarding delivery, so a DB fault returns 500 for a registered address and a clean 200 for an unregistered one.			
Evidence	IT-AUTH-017			
Remediation	Wrap the whole post-lookup block and always return the same generic 200.			

QA-05	Medium	CORS accepts requests from any origin	OWASP API8	OPEN
Observed	Access-Control-Allow-Origin returns *, so any website can call the API from a visitor's browser.			
Evidence	SEC-API8-001			
Remediation	Replace with an explicit origin allowlist.			

QA-06	Medium	All standard security response headers are missing	OWASP API8	OPEN
Observed	X-Content-Type-Options, X-Frame-Options, HSTS and CSP are all absent because helmet is not registered. The app is framable and MIME-sniffable.			
Evidence	SEC-API8-002, .005			
Remediation	app.use(helmet()) in main.ts.			

QA-07	Medium	Oversized request body returns 500 instead of 413	OWASP API4	OPEN
Observed	A 2MB JSON body produced HTTP 500: Express's PayloadTooLargeError is not an HttpException, so the global filter maps it to a generic 500.			
Evidence	SEC-API4-002			
Remediation	Set an explicit body limit and map PayloadTooLargeError to 413.			

QA-09	Medium	Uploaded file type is trusted from the client, never sniffed	OWASP API3	OPEN
Observed	Validation checks only the multipart Content-Type header, so HTML bytes declared as application/pdf are stored and later served with that forced type into an iframe. Mitigating factor: uploading is admin-only.			
Evidence	IT-RES-003			
Remediation	Verify magic bytes server-side and derive the stored mimeType from them.			

QA-10	Medium	Non-ASCII filenames are not encoded in Content-Disposition	Functional	OPEN
Observed	quoteFileName strips quotes, CR and LF but passes non-Latin-1 characters through raw, which can make presigning throw and break view and download for that file permanently.			
Evidence	UT-ST0-006			
Remediation	Emit RFC 5987 filename*=UTF-8 alongside an ASCII-only fallback.			

QA-11	Low	Framework disclosed via X-Powered-By	OWASP API9	OPEN
Observed	Responses advertise X-Powered-By: Express, narrowing the search for version-specific exploits.			
Evidence	SEC-API9-001			
Remediation	app.disable('x-powered-by'); helmet does this automatically.			

QA-12	Low	Document viewer title reads Loading while showing an error	Functional	OPEN
Observed	The header only distinguishes 'has document' from 'no document', so during an error the title bar still says Loading while the body shows the failure.			
Evidence	UAT (viewer)			
Remediation	Branch the title on isLoading / error / loaded explicitly.			

QA-14	Low	User-supplied fullName is stored without sanitisation	OWASP API3	OPEN
Observed	A script payload in fullName is persisted verbatim. React escapes on render so there is no XSS today, but the raw value would be live for any future non-React consumer.			
Evidence	SEC-INJ-002			
Remediation	Strip or encode control markup on write, and keep escaping on output.			

QA-15	Low	Path-traversal sequences survive into the storage object key	Functional	OPEN
Observed	An upload named ../etc/passwd.pdf yields a key containing that sequence. S3-compatible stores treat keys as opaque strings, so nothing escapes the bucket today.			
Evidence	IT-RES-006			
Remediation	Normalise the basename before composing the key.			

QA-16	Low	Password policy enforces length only	OWASP API2	OPEN
Observed	An eight-character password such as 12345678 is accepted. No complexity rule and no breached-password screening.			
Evidence	UT-DT0-006			
Remediation	Raise the floor to 10-12 characters and screen against a common-password list.			

QA-17	High	Asymmetric video mesh - the reported 3-2-1 failure	Functional	FIXED
Observed	With three students on a call, one saw everyone, one saw two and one saw only themselves. The old rule (whoever joins offers to everyone already in the call) announced inCall BEFORE building the offer list, so two people joining together both offered. The second offer hit a peer in have-local-offer, setRemoteDescription threw InvalidStateError, and with no try/catch and no retry that pair stayed dead. Not a network fault - it reproduced on a single Wi-Fi.			
Evidence	UT-MESH-001 . . 009			
Remediation	FIXED: a deterministic initiator (lower socket id offers) removes glare by construction; an ensureMesh pass on join, on roster change and every 3s heals missing or failed links; and all signalling is wrapped so one bad frame cannot wedge a connection.			

QA-18	High	Admin locked out of the site by a client-side domain check	Functional	FIXED
Observed	A hardcoded @mmcoe.edu.in check on the login form blocked the seeded admin account - the only one that can upload papers. The same check on forgot-password also removed its recovery path and reintroduced an enumeration signal.			
Evidence	UAT (login)			
Remediation	FIXED: removed from login, forgot-password and resend-verification, which act on accounts that already passed the server-side allowlist. Kept on signup, where the rule genuinely applies.			

QA-19	Medium	Stale cache showed unlocked papers after logout	Functional	FIXED
Observed	React Query's 30s staleTime left a signed-out user seeing View and Download on locked papers; clicking them returned 401 and hard-redirected to /login.			
Evidence	UAT (gating)			
Remediation	FIXED: the query cache is cleared on login and logout, since responses are auth-dependent.			

QA-08	Medium	Unknown routes rendered a completely blank page	Functional	FIXED
Observed	App.tsx had no catch-all route, so React Router matched nothing and #root stayed empty - not even the header. With Vercel's SPA rewrite serving index.html for every path, any typo or stale link was a white screen.			
Evidence	UAT - 014			
Remediation	FIXED: a NotFoundPage inside the layout route, so a lost visitor keeps the header and gets links back to the catalogue and to study rooms.			

QA-13	Low	Signup placeholder advertised a domain the server rejects	Functional	FIXED
Observed	The email field suggested you@youruniversity.edu.in while the only allowlisted domain was mmcoe.edu.in, so following the hint failed.			
Evidence	UAT (signup)			
Remediation	FIXED: the placeholder now shows username@mmcoe.edu.in.			

QA-20	High	Vercel deployment blocked by a lockfile mismatch	Functional	FIXED
Observed	pnpm-lock.yaml was committed carrying a socket.io-client entry while backend/package.json - which declares it - was left uncommitted, so pnpm install --frozen-lockfile refused with ERR_PNPM_OUTDATED_LOCKFILE and no deployment could complete.			
Evidence	Vercel build log			
Remediation	FIXED: package.json committed with the lockfile; the whole install, typecheck and build chain was reproduced locally before and after.			

3. Remediation roadmap

Order	Action	Addresses	Effort
1	Register @nestjs/throttler globally; tighter limits on /auth/login, /auth/signup and /auth/forgot-password	QA-01, QA-04	~1 hour
2	app.use(helmet()) and replace cors:true with an explicit origin allowlist	QA-05, QA-06, QA-11	~30 min
3	Move the mail send off the request path (fire-and-forget) and wrap the reset writes in try/catch	QA-02, QA-03	~30 min
4	Add a catch-all 404 route in App.tsx	QA-08	~20 min
5	Sniff magic bytes on upload; derive stored mimeType from the sniffed value	QA-09	~1 hour
6	RFC 5987-encode Content-Disposition filenames	QA-10	~30 min
7	Map PayloadTooLargeError to 413 in HttpExceptionFilter	QA-07	~20 min
8	Fix viewer title states; drive signup placeholder/error from the domain allowlist	QA-12, QA-13	~40 min
9	Raise password floor to 10-12 chars; sanitise fullName and storage-key basenames	QA-14, QA-15, QA-16	~1 hour

3.1 A note on scope

This engagement was described as low-risk because the audience is students. That is worth qualifying: ScholarBase stores student names, college email addresses, argon2 password hashes and password-reset tokens. Under India's DPDP Act 2023 those are personal data, and password reuse means a credential compromise here can propagate to other services. The severities above are assigned on that basis rather than on the assumption that the data is disposable.

Realtime module results

Driven by two authenticated socket clients against the running gateway. Every authorization rule is asserted from the client that should be refused, not merely from the happy path.

ID	Module	Check	Res.
RT-PRES-001	Presence	Joining emits a roster to the joiner	PASS
RT-PRES-002	Presence	Existing members are told when someone joins	PASS
RT-CHAT-001	Chat	A message reaches the other participant	PASS
RT-CHAT-002	Chat	An over-length message is rejected, not broadcast	PASS
RT-CHAT-003	Chat	Typing indicator is relayed	PASS
RT-WB-001	Whiteboard	Owner can claim the board	PASS
RT-WB-002	Whiteboard	A second person cannot seize an owned board	PASS
RT-WB-003	Whiteboard	SECURITY — drawing without a grant is ignored	PASS
RT-WB-004	Whiteboard	Ask-to-draw reaches the owner only	PASS
RT-WB-005	Whiteboard	Owner can grant the pen	PASS
RT-WB-006	Whiteboard	A granted student's stroke reaches the room	PASS
RT-WB-007	Whiteboard	Out-of-range coordinates are rejected	PASS
RT-WB-008	Whiteboard	Undo removes the caller's own stroke	PASS
RT-WB-009	Whiteboard	SECURITY — a non-owner cannot clear the board	PASS
RT-WB-010	Whiteboard	Owner can clear the board	PASS
RT-PTR-001	Screen pointer	SECURITY — pointer is dropped when nobody is sharing	PASS
RT-PTR-002	Screen pointer	Pointer relays while a screen share is active	PASS
RT-PTR-003	Screen pointer	Malformed / out-of-range pointer coordinates are rejected	PASS
RT-SIG-001	WebRTC signalling	Signals route to a peer in the same room	PASS
RT-SIG-002	WebRTC signalling	SECURITY — signals to a non-member socket are refused	PASS
RT-PRES-003	Presence	Leaving notifies the room	PASS

4. Test case inventory

4.1 Unit tests (61 cases, all passed)

Scope: logic that can be exercised with no I/O. Covers JWT TTL parsing, the viewer MIME allowlist, Content-Disposition sanitisation, presigned-URL shaping, and every request DTO's validation rules.

Test case	Result
UT-VCR-001 a 16:9 capture in a taller box gets horizontal bars	PASS
UT-VCR-002 a 4:3 capture in a wider box gets vertical bars	PASS
UT-VCR-003 falls back to the whole box before metadata loads	PASS
UT-VCR-004 the centre of the picture is (0.5, 0.5)	PASS
UT-VCR-005 the picture's top edge is y=0, NOT the box's top edge	PASS
UT-VCR-006 SECURITY/CORRECTNESS — a pointer over a letterbox bar is rejected	PASS
UT-VCR-007 the element's own page offset is subtracted	PASS
UT-VCR-008 round-trips — normalize then position lands back where it started	PASS
UT-VCR-009 the same normalized point maps to different pixels on different windows	PASS
UT-MIME-001 accepts every type declared viewable	PASS
UT-MIME-002 accepts PDF, the only type papers uploads can produce	PASS
UT-MIME-003 rejects renderable-but-dangerous types	PASS
UT-MIME-004 rejects office types that cannot render in an iframe	PASS
UT-MIME-005 rejects empty/garbage input rather than throwing	PASS
UT-MIME-006 is case-sensitive and does not strip parameters (documents current behaviour)	PASS
UT-DUR-001 converts each supported unit to milliseconds	PASS
UT-DUR-002 parses the production defaults used by the app	PASS
UT-DUR-003 tolerates surrounding whitespace	PASS
UT-DUR-004 tolerates internal whitespace between amount and unit	PASS
UT-DUR-005 rejects malformed values rather than silently defaulting	PASS
UT-DUR-006 accepts zero without throwing (boundary)	PASS
UT-MESH-001 simultaneous joins make BOTH sides offer — glare on every pair	PASS
UT-MESH-002 with frames still in flight, one pair dies while the others work	PASS
UT-MESH-003 retrying cannot save it — the rule itself has no arbitration	PASS
UT-MESH-004 with everyone visible, every pair gets exactly one offer	PASS
UT-MESH-005 no pair can ever double-offer, whoever clicks first	PASS
UT-MESH-006 the same in-flight state that broke the old rule now connects everything	PASS
UT-MESH-006b a pair whose initiator is still blind is pending, not broken	PASS
UT-MESH-007 reconciliation completes the mesh on the next pass	PASS
UT-MESH-008 reconciling again is idempotent — no duplicate offers	PASS
UT-MESH-009 scales — a room of six has one offerer per pair and no glare	PASS
UT-DTO-001 normalizes email to trimmed lowercase before validation	PASS
UT-DTO-002 rejects malformed email addresses	PASS
UT-DTO-003 enforces a minimum password length	PASS
UT-DTO-004 rejects an empty full name	PASS
UT-DTO-005 signup's password floor agrees with the shared MIN_PASSWORD_LENGTH constant	PASS
UT-DTO-006 does not enforce any password complexity (documents current policy)	PASS

Test case	Result
UT-DTO-007 normalizes email so login is case-insensitive	PASS
UT-DTO-008 ForgotPasswordDto requires a valid email	PASS
UT-DTO-009 ResetPasswordDto rejects an empty token	PASS
UT-DTO-010 ResetPasswordDto enforces MIN_PASSWORD_LENGTH	PASS
UT-DTO-011 ForgotPasswordDto does not normalize case (asymmetry with login/signup)	PASS
UT-DTO-012 coerces a numeric query string to a number	PASS
UT-DTO-013 treats an empty query value as absent rather than 0	PASS
UT-DTO-014 rejects a non-numeric year instead of silently filtering by NaN	PASS
UT-DTO-015 rejects a non-UUID subjectId (prevents raw values reaching Prisma)	PASS
UT-DTO-016 enforces message limit boundaries 1..200	PASS
UT-DTO-017 enforces academic-year sanity bounds on upload	PASS
UT-STO-001 download URL requests an attachment disposition	PASS
UT-STO-002 view URL requests an inline disposition and pins the content type	PASS
UT-STO-003 neutralizes a double quote so the filename cannot escape the quoted string	PASS
UT-STO-004 neutralizes CR and LF so a header cannot be injected	PASS
UT-STO-005 neutralizes backslash escapes	PASS
UT-STO-006 does NOT encode non-ASCII filenames (documents known defect QA-004)	PASS
UT-STO-007 applies the documented default expiries (5 min download, 30 min view)	PASS
UT-STO-008 resolves logical bucket names through env overrides	PASS
UT-SFU-001 forwards bucket and file key to the storage layer for downloads	PASS
UT-SFU-002 forwards the mime type for views (required to render inline)	PASS
UT-SFU-003 serializes expiry as an ISO string in the download DTO	PASS
UT-SFU-004 view DTO carries the metadata the viewer needs, and no storage key	PASS
UT-SFU-005 is agnostic to the record's concrete model (structural typing)	PASS

4.2 Integration tests (74 cases, all passed)

Scope: services wired against mocked Prisma, with real argon2 and real HMAC. Two cases (IT-AUTH-017/018) are characterisation tests - they pass because they successfully demonstrate defects QA-02 and QA-03.

Test case	Result
IT-WB-001 the first claimant owns the board	PASS
IT-WB-002 a second person cannot take a board that is actively owned	PASS
IT-WB-003 re-claiming your own board is a no-op, not a failure	PASS
IT-WB-004 a board held by a socket that has left can be claimed (crashed-owner recovery)	PASS
IT-WB-005 releasing keeps the strokes — it hands over the pen, it does not erase	PASS
IT-WB-006 grants are dropped when the owner leaves — they were the owner's to give	PASS
IT-WB-007 releasing a board you do not own does nothing	PASS
IT-WB-008 the owner may always draw	PASS
IT-WB-009 everyone else is refused until granted, and again once revoked	PASS
IT-WB-010 nobody can draw on a room that has no board	PASS
IT-WB-011 chunks with the same id extend one stroke rather than creating many	PASS
IT-WB-012 SECURITY — you cannot extend somebody else's stroke	PASS
IT-WB-013 undo removes only the caller's most recent stroke	PASS
IT-WB-014 undo with nothing of your own returns undefined and changes nothing	PASS

Test case	Result
IT-WB-015 the stroke buffer is bounded, dropping oldest first	PASS
IT-WB-016 clear empties the strokes but keeps the board and its owner	PASS
IT-WB-017 the board survives the room emptying, until the grace period elapses	PASS
IT-WB-018 rejoining inside the grace window saves the board (the reload case)	PASS
IT-WB-019 closing the room drops the board immediately, with no grace period	PASS
IT-WB-020 a disconnect releases the board across every room the socket was in	PASS
IT-RES-001 rejects a request with no file attached	PASS
IT-RES-002 rejects a non-PDF declared content type	PASS
IT-RES-003 SECURITY — accepts HTML bytes when the client declares application/pdf	PASS
IT-RES-004 refuses a byte-identical duplicate via checksum	PASS
IT-RES-005 derives a namespaced storage key with a random component	PASS
IT-RES-006 SECURITY — traversal sequences in the filename survive into the storage key	PASS
IT-RES-007 accepts the documented office formats	PASS
IT-RES-008 rejects an unsupported type for notes	PASS
IT-RES-009 papers download/view 404 when the row does not exist	PASS
IT-RES-010 notes download/view 404 when the row does not exist	PASS
IT-RES-011 each resource presigns against its own bucket	PASS
IT-GATE-001 exactly one paper per (department, semester) is free	PASS
IT-GATE-002 nothing is locked for a logged-in caller	PASS
IT-GATE-003 the free paper is stable across calls (not order-dependent)	PASS
IT-GATE-004 SECURITY — anonymous view/download of a locked paper is refused	PASS
IT-GATE-005 anonymous access to the free paper is allowed	PASS
IT-GATE-006 a logged-in caller may open a paper that is locked for visitors	PASS
IT-GATE-007 a missing paper still 404s rather than leaking the lock state	PASS
IT-AUTH-001 rejects an email outside the allowed university domains	PASS
IT-AUTH-002 rejects a duplicate account with 409 rather than overwriting	PASS
IT-AUTH-003 stores an argon2 hash, never the plaintext password	PASS
IT-AUTH-004 normalizes the email to lowercase before persisting	PASS
IT-AUTH-025 issues NO session at signup — the account is unusable until confirmed	PASS
IT-AUTH-026 the confirmation link mailed at signup is a hash-stored single-use token	PASS
IT-AUTH-027 verification hash is domain-separated from BOTH the refresh and reset hashes	PASS
IT-AUTH-005 returns an identical generic error for unknown user and wrong password	PASS
IT-AUTH-006 issues tokens and never returns the password hash to the client	PASS
IT-AUTH-007 persists only an HMAC of the refresh token, never the raw value	PASS
IT-AUTH-028 login is refused with 403 while the address is unconfirmed	PASS
IT-AUTH-029 the gate runs only after the password check, so it can't confirm an account for free	PASS
IT-AUTH-030 login succeeds once the address is confirmed	PASS
IT-AUTH-031 verifyEmail marks the account verified and burns the token atomically	PASS
IT-AUTH-032 an unknown or expired confirmation token is rejected with one generic message	PASS
IT-AUTH-033 re-opening a spent link for an already-verified account succeeds instead of erroring	PASS
IT-AUTH-034 resendVerification is silent for unknown and already-verified addresses	PASS
IT-AUTH-035 resendVerification issues a fresh link and kills the previous one	PASS

Test case	Result
IT-AUTH-036 a mail failure during signup does not fail the signup itself	PASS
IT-AUTH-008 rejects an expired refresh token	PASS
IT-AUTH-009 rejects an unknown/revoked refresh token	PASS
IT-AUTH-010 rotates the token — the presented one is revoked after use	PASS
IT-AUTH-011 resolves silently for an unregistered address (no enumeration via response)	PASS
IT-AUTH-012 invalidates any outstanding reset link before issuing a new one	PASS
IT-AUTH-013 stores only a hash of the reset token; the raw token goes to email only	PASS
IT-AUTH-014 reset-token hash is domain-separated from the refresh-token hash	PASS
IT-AUTH-015 honours the configured TTL when setting expiry	PASS
IT-AUTH-016 a mail delivery failure does not surface to the caller	PASS
IT-AUTH-017 SECURITY — a DB failure DOES surface, creating a 500-vs-200 enumeration oracle	PASS
IT-AUTH-018 SECURITY — the registered path performs strictly more awaited work (timing oracle)	PASS
IT-AUTH-019 rejects an unknown token	PASS
IT-AUTH-020 rejects an already-used token (single use enforced)	PASS
IT-AUTH-021 rejects an expired token	PASS
IT-AUTH-022 gives the same generic message for unknown, used and expired tokens	PASS
IT-AUTH-023 on success, burns the token and revokes every live session atomically	PASS
IT-AUTH-024 the new password is argon2-hashed before it reaches the database	PASS

4.3 API E2E and OWASP security tests (63 cases)

Executed over HTTP against the running server, so global guards, pipes, filters and CORS middleware are all in the path. 'Actual' records exactly what the server returned.

ID	Test	Actual result	Res.
E2E-001	Health endpoint is public and healthy	200	PASS
E2E-002	Signup refuses a non-university email domain	400	PASS
E2E-003	Signup creates the account but issues NO session until the email is confirmed	201, tokens=false, body={"message":"Account created. Check your email for a confirmation link to finish"}	PASS
E2E-004	Duplicate signup is rejected with 409	409	PASS
E2E-005a	Login is refused with 403 while the address is unconfirmed	403: Confirm your email before logging in. Check your inbox for the link we	PASS
E2E-005b	A bogus confirmation token is rejected with 400	400	PASS
E2E-005c	A valid confirmation token verifies the account	200: Email confirmed. You can log in now.	PASS
E2E-005d	Re-opening a spent link is handled gracefully, not as an error	200: Your email is already confirmed. You can log in.	PASS
E2E-005	Login succeeds once the address is confirmed	200, token=true	PASS
E2E-006	Login with wrong password is rejected	401	PASS
E2E-007	GET /auth/me returns the caller's profile	200, email=qa-student-1786708714740@mmcoe.edu.in	PASS
E2E-008	GET /auth/me without a token is rejected	401	PASS
E2E-009	Refresh token rotates and the consumed token is revoked (replay blocked)	first=200, replay=401	PASS
E2E-010	Seeded admin can authenticate	200, role=admin	PASS
E2E-011	Subject catalog is publicly readable	200, n=78	PASS
E2E-012	Question paper list is publicly readable, with per-paper lock state	200, n=18, free=3, locked=15	PASS
E2E-012a	SECURITY — anonymous view/download of a LOCKED paper is refused	view=401, download=401	PASS
E2E-013	Anonymous user may open the free paper for the semester	500, keys=statusCode,message	WARN
E2E-014	View DTO does not leak the internal storage key	statusCode,message	PASS
E2E-015	Anonymous user may download the free paper for the semester	500	WARN
E2E-017	Unknown paper id returns 404, not 500	404	PASS
E2E-018	Notes list is publicly readable (metadata only)	200	PASS
SEC-API5-001	Student is denied admin function: Upload question paper	403	PASS
SEC-API5-002	Student is denied admin function: Upload note	403	PASS
SEC-API5-003	Student is denied admin function: Admin study-room oversight	403	PASS
SEC-API5-004	Student is denied admin function: Create subject	403	PASS
SEC-API5-005	Student is denied admin function: Create year level	403	PASS
SEC-API5-006	Student is denied admin function: Create exam type	403	PASS
SEC-API5-007	Anonymous caller is denied the admin oversight endpoint	401	PASS
SEC-API11-001	Anonymous user cannot obtain a note view URL	no notes seeded — untested	INFO
SEC-API11-003	/auth/me is scoped to the bearer's own account (no id parameter to tamper)	id=self	PASS
SEC-API11-004	Study room listing requires authentication	auth=200, anon=401	PASS
SEC-API2-001	Rejected: No Authorization header	401	PASS
SEC-API2-002	Rejected: Malformed token string	401	PASS
SEC-API2-003	Rejected: Structurally valid JWT signed with the wrong secret	401	PASS

ID	Test	Actual result	Res.
SEC-API2-004	Rejected: alg:none unsigned token (algorithm confusion)	401	PASS
SEC-API2-005	Rejected: Expired token	401	PASS
SEC-API2-006	Role claim tampering: token says ADMIN, database says student	403	PASS
SEC-API2-007	Logout revokes the refresh token	logout=204, refresh=401	PASS
SEC-API3-001	Mass assignment: extra 'role' field at signup cannot grant admin	400, role=n/a	PASS
SEC-API3-002	Login response contains no password hash or token hash	clean	PASS
SEC-API3-003	Public paper DTO omits storage key and checksum	fields: id,subjectId,examTypeId,academicYear,fileName,fileSizeBytes,uploadStatus,ingestionStatus,createdAt,locked	PASS
SEC-API4-001	Brute-force protection on login (25 bad attempts)	0 throttled, all 25 answered 401 in 3149ms	FAIL
SEC-API6-001	Password-reset requests are rate limited per address	6 accepted (200), 0 throttled	FAIL
SEC-API4-002	Oversized JSON body is rejected rather than processed	500	WARN
SEC-API6-002	Forgot-password timing does not reveal whether an account exists	registered 638.5ms vs unregistered 90.6ms (7.05x)	FAIL
SEC-API6-004	Resend-verification answers identically for known, unknown and already-verified addresses	200/200, identical=true	PASS
SEC-API6-003	Forgot-password response body/status is identical for both cases	200/200, identical=true	PASS
SEC-API8-001	CORS does not reflect/allow arbitrary origins	Access-Control-Allow-Origin: *	FAIL
SEC-API8-002	Security header present: x-content-type-options	(absent)	FAIL
SEC-API8-003	Security header present: x-frame-options	(absent)	FAIL
SEC-API8-004	Security header present: strict-transport-security	(absent)	FAIL
SEC-API8-005	Security header present: content-security-policy	(absent)	FAIL
SEC-API9-001	Server does not advertise its framework via X-Powered-By	Express	FAIL
SEC-API8-006	Malformed request does not leak stack traces or internals	clean (400)	PASS
SEC-API9-002	TRACE verb is not served	not sent by client ('TRACE' HTTP method is unsupported.)	INFO
SEC-API9-003	PUT on a GET-only route is not served	404	PASS
SEC-API9-004	PATCH on a GET-only route is not served	404	PASS
SEC-API9-005	DELETE on a GET-only route is not served	404	PASS
SEC-API7-001	No user-controlled URL is fetched server-side	Brevo endpoint is a module constant	PASS
SEC-API10-001	Third-party (Brevo) response is not reflected to API clients	provider body is logged, generic error thrown	PASS
SEC-INJ-001	SQL-injection style input is rejected by validation, not passed to the ORM	400	PASS
SEC-INJ-002	Script payload in fullName is stored raw (relies on React escaping at render)	stored verbatim	WARN

4.4 User acceptance testing (17 scenarios)

Driven through a real browser against the running application - navigation, forms, modals, route guards, theming and responsive layout.

ID	Scenario	Observed	Res.
UAT-001	Anonymous landing page renders department catalogue	12 department links; verified on the production build	PASS
UAT-002	Subject holding only locked papers	Both papers show the lock overlay, no View button	PASS
UAT-003	Subject holding the semester's free paper	Free-preview badge + View/Download on that one paper only	PASS
UAT-004	Hover a locked paper card	Overlay reveals 'Log in to view all papers'	PASS
UAT-005	Anonymous user opens /admin	Redirected to /login	PASS
UAT-006	Logged-in student opens /admin	Redirected away; admin UI not rendered	PASS
UAT-007	Sign up with an allowlisted college domain	Check-your-inbox panel; no session stored	PASS
UAT-008	Attempt login before confirming the address	403 with actionable message and a resend link	PASS
UAT-009	Open the emailed confirmation link	Confirmed; exactly one POST despite StrictMode double-effect	PASS
UAT-010	Log in after confirming	Session established; emailVerifiedAt populated	PASS
UAT-011	Open /reset-password with no token	'Reset link missing' with a recovery link	PASS
UAT-012	Whiteboard: claim, grant, draw, undo, clear	Verified against a second live client	PASS
UAT-013	Whiteboard: a remote stroke paints on the canvas	3,550 to 15,500 painted px, colour matched the sender	PASS
UAT-014	Navigate to an unknown URL	Custom 404 with header and routes back	PASS
UAT-015	Toggle dark theme and reload	Applied and persisted across reload	PASS
UAT-016	Home and subject pages at 375px	No horizontal overflow	PASS
UAT-017	Console hygiene on the production build	Zero errors; dev-only HMR noise excluded	PASS

Appendix A - Reproducing these results

The suites are committed to the repository. Unit and integration tests need no running services; the API suite needs the backend running and reads admin credentials from backend/.env. It creates throwaway accounts and deletes them on completion, so it must be pointed at a development database, never production.

Command	What it runs
<code>pnpm --filter @scholarbase/backend test</code>	77 unit + integration specs (no services required)
<code>node backend/test/e2e/api-security-suite.js</code>	57 E2E + OWASP checks against a running backend
<code>API_BASE=https://<host>/api node ../api-security-suite.js</code>	Point the same suite at a deployed environment

Appendix B - Environment and coverage limits

Limitation	Detail
Object storage offline locally	Local MinIO was not running (Docker unavailable), so E2E-013/015/016 returned 500. Presigned-URL generation was verified working earlier in the same environment; retest with storage up to close these out.
Notes corpus empty	No notes were uploaded at test time, so SEC-API1-001 (anonymous note access) could not be exercised against real data. The equivalent control was verified at the controller level - the route omits @Public() and the global JwtAuthGuard applies.
Study rooms partially covered	Room listing and admin oversight authorisation were tested. Live WebSocket signalling, WebRTC media and multi-participant presence were not - they need multiple concurrent real clients.
Frontend unit tests absent	The frontend has no test tooling installed; its behaviour was covered through UAT rather than component tests. Adding Vitest + Testing Library would let the viewer state machine and route guards be pinned down in CI.
Load and soak testing	Out of scope. Throughput, connection limits and the Neon free-tier connection ceiling under concurrent load were not measured.